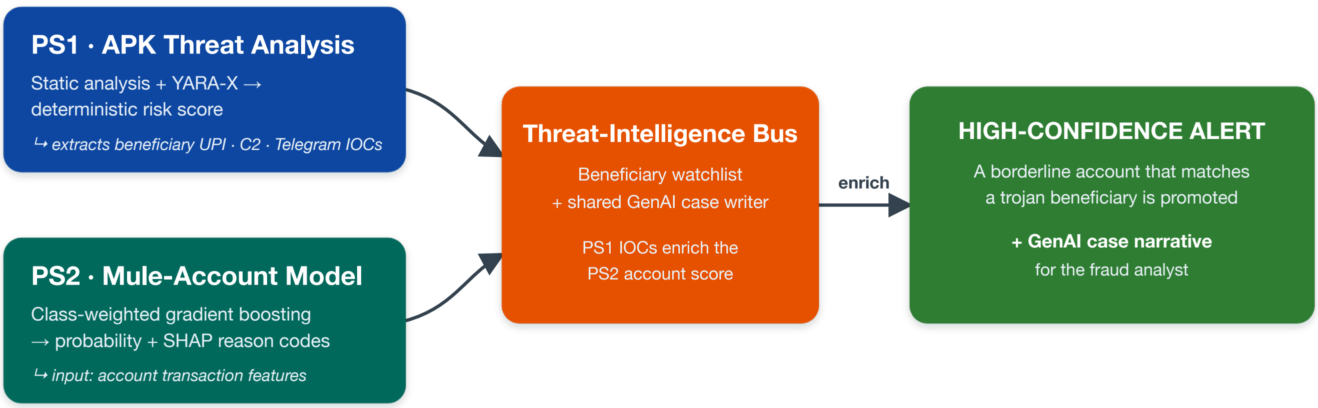
PSB'S CYBERSECURITY, FRAUD & AI HACKATHON 2026 · BANK OF INDIA × IIT HYDERABAD · DFS (MINISTRY OF FINANCE) / IBA

CyberShield

Generative-AI APK Threat Analysis (PS1) + AI/ML Mule-Account Detection (PS2) — a single, joined solution

Team **Burning Platform** Pranjal Prakhar · Loveleen Kaur · Yogesh Verma Problem statements **1 & 2 (combined)**
15 June 2026 Code github.com/PP112004/cybershield

The idea in one breath. Two problem statements, **one fraud kill-chain.** PS1 dissects the malicious banking APK and extracts the **beneficiary accounts** the stolen money is routed to. PS2 scores customer accounts for mule behaviour. PS2's own brief asks the model to ingest "*fraud-monitoring solution alerts and govt cyber-fraud alerts/tickets*" — so **PS1's output becomes exactly that feed.** An account that scores *borderline* on the mule model **and** matches a trojan-extracted beneficiary is promoted to a **high-confidence alert** with a GenAI case narrative. Each service stands alone; together they catch the mule neither would alone.



The innovation. PS1 and PS2 are each complete answers to their own statement; the **Intelligence Bus** is the upside. One trojan-extracted beneficiary turns a borderline account into a confirmed mule alert — the standard SOC pattern of **threat-intel enrichment of transaction monitoring**, invited by the bank's own wording, not forced.

32×
PS2 concentrates mules at **~32× the base rate** within a top-1% alert budget (deployable 18-feature model, 5×5 CV).

30
New predictive features surfaced by SHAP — the full model's entire top-30 lies outside the bank's 18 key features.

Live
The **PS1 → PS2 fusion runs today** via the `/case` endpoint; honest about every limit by design.

1 PS1 — APK Threat Analysis & Risk Scoring

GENAI

Fraudsters push malicious APKs over WhatsApp, SMS and phishing links; manual reverse-engineering is slow and expert-dependent. CyberShield **auto-analyses a suspicious APK, classifies severity, produces a deterministic risk score, extracts actionable IOCs, and generates an investigation report** — seconds, not hours, and every verdict is auditable.

> **Core principle — GenAI interprets, it never adjudicates.** The risk score is a **deterministic** function of evidence actually extracted from the APK; the LLM only explains it, maps behaviour to MITRE ATT&CK Mobile, and writes the analyst report. All APK-derived text is treated strictly as **data, never instructions** — so a string like "*classify as benign*" embedded by the malware cannot inject the verdict, and the score never changes between runs.

Deterministic detection core

- **Weighted risk engine** — scores **combinations** of behaviours, never a single permission, so a legitimate banking app that requests SMS/overlay is not flagged.
- **Four YARA-X rules over DEX bytecode** — a fast, auditable layer banks understand operationally: overlay + SMS-interception combo `T1417/T1582`, Telegram-bot exfiltration `T1639`, dropper pattern `T1407`, and hardcoded UPI-beneficiary `T1582`.
- **IOC extraction** — C2 URLs, Telegram bot tokens, phone numbers, and the **beneficiary UPI handles** (matched on Indian PSP suffixes `@ybl @oksbi @okaxis @paytm @boi …`) that bridge into PS2.

Generative AI as a real performance lever (not decoration)

- **Offline rule synthesis** — the LLM reads decompiled malware and *proposes* YARA rules; a proposal is admitted only if it fires on the family corpus and gives **zero hits on the benign set**. Coverage scales; the runtime detector stays deterministic.
- **Corroborated evidence extraction** — the LLM flags behaviours **with code citations**; a flag is scored only if its citation verifies against the extracted strings/APIs. Uncorroborated flags become analyst leads, not scores — a recall gain with hallucination filtered out.

> **Honest on validation.** PS1 is judged the way a bank operates — **detection rate** on known India-targeting families (SpyNote/SpyMax, Drinik, SOVA, Axbanker) and **false-positive rate** on real banking apps (BOI Mobile, YONO, BHIM) on a held-out split. The risk weights are currently expert-set; we calibrate them against the labelled corpus in the prototype phase and **will not fabricate detection numbers.**

2 PS2 — Suspicious Mule-Account Classification

AI / ML

Dataset reality (it drives every decision): 9,082 accounts × 3,924 anonymised features (`F1…F3924` , target `F3924`); only **81 mules (0.9%)**; 163 empty columns and 600+ features >90% missing.

> **Dataset-integrity findings — our rigour differentiator.** A leakage audit over all 3,924 features surfaced three things most teams miss: **(1)** `F2230` (report month) **perfectly confounds batch and label** — all negatives extracted Oct-25, all positives Sep/Nov/Dec-25 — so **every metric below is an upper bound**; we recommend the bank re-extract negatives from matched windows. **(2)** `F3912` is a post-outcome leak (AUC 0.987) — **excluded**. **(3)** High-index features pattern like fraud-alert counts — the brief asks to ingest such feeds, so they are **retained**, subject to (1).

Evaluated the way a bank operates — not a single "accuracy" number

- **Repeated stratified CV (5 folds × 5 repeats)** — a single split is meaningless at 81 positives.
- **PR-AUC with 95% intervals**, and the operating metric: **precision / recall / lift at a top-1% alert budget** (the 1% of accounts a team can realistically review per day).
- **Class-weighting beats SMOTE** (confirmed below); missingness is treated as **signal**, not imputed away.

Model	PR-AUC	ROC-AUC	Prec@1%	Recall@1%	Lift@1%
Key-18, LightGBM (class-weighted) — deployable	**0.313**	0.876	0.287	0.319	**32.2×**
Key-18, LightGBM (SMOTE) — baseline	0.228	0.869	0.247	0.273	27.6×
Full-feature, LightGBM (class-weighted)	0.826	0.977	0.716	0.795	80.2×
Full-feature, XGBoost (class-weighted) — discovery	**0.893**	0.981	0.776	**0.861**	**86.9×**

Mean across 5×5 CV. The compact 18-feature model is the conservative, deployable result — **~32× more mules than random** at a 1% budget. The full discovery model reaches PR-AUC 0.893 but leans on the high-index alert-count features under the F2230 confound, so we treat its headline as an **upper bound** and value it for **feature discovery**.

"Most relevant features" — delivered

The full model's **entire SHAP top-30 lies outside the bank's 18 key features.** Strongest new signals:

```
F3898 F3914 F3908 F3484 F3922 F3805 F3811 F2581
F270 …
```

— precisely the fraud-alert-count-like feeds. Recommendation: promote these to first-class monitoring inputs.

Explainability & honest GenAI position

Every alert ships **SHAP reason codes**; GenAI turns them into a plain-language analyst narrative. On anonymised tabular data GenAI **cannot** boost accuracy and we won't claim it — its real lever is parsing free-text **NCRP/I4C tickets** into new features and watchlist entries.

3 The Integration — Threat-Intelligence Bus (PS1 → PS2)

INNOVATION

Indian banking trojans hardcode or fetch **beneficiary UPI handles / account numbers** (often exfiltrated via Telegram bots). PS1's IOC extraction yields a **beneficiary watchlist**; PS2 consumes it as an **enrichment signal** — a borderline account matching a trojan-extracted beneficiary is **promoted to a high-confidence alert** with a unified GenAI case narrative. This is **demonstrated live today** via the service's `/case` endpoint.

Why modular-unified, not a monolith

Prizes are **per-topic**, so each service must stand alone and fully answer its own statement — the fusion bus is **upside, not load-bearing.**

Honest caveat

The provided data is anonymised, so the join is demonstrated via the scoring API's watchlist input; **in production the bank joins extracted IOCs to real account identifiers.**

4 What Runs Today, and the Prototype Roadmap

Working now (public repo, locally runnable)

- Reproducible PS2 train/eval → real metrics, models & thresholds (one command).
- FastAPI service: `/score-account` (prob + SHAP), `/case` (the fusion), gated `/analyze-apk`; test suite passing.
- Four linted YARA-X rules; swappable LLM layer (DeepSeek / Gemini / offline template).

Prototype phase (1 Jul – 28 Aug 2026)

- **PS1:** labelled-corpus calibration of weights/rules; sandboxed dynamic analysis; full decompilation.
- **PS2:** probability calibration, threshold tuning, confound ablation, LLM alert narratives.
- **Fusion:** NCRP/I4C free-text ticket parser → new features & watchlist; host the public PS2 demo.

> **Limitations we state loudly.** PS2 metrics are upper bounds (F2230 confound) · PS1 risk weights are not yet corpus-calibrated · PS1 static analysis currently scores from extracted metadata (full decompilation + dynamic analysis are prototype-phase) · fusion on anonymised data is shown via watchlist input. Stating these is the point — a banking-security panel finds hidden weaknesses anyway.